

Security Testing Report Example

Here are some of the sections that may be included in a security testing report:

Executive summary

This serves as a high-level view of the vulnerabilities that were found and their possible impact on the business. The executive summary should be short, concise and clear. It should be something that non-technical readers can review and understand. It may also include graphs, charts, and other types of visuals.

A detailed outline or discussion of the security risks that were found

This is a more detailed analysis of the vulnerabilities that were uncovered during testing. This may include information on what types of test were performed, how they were performed and a summary of the data gained from the testing (with the full raw data included in a separate section). Depending on the audience, this may include technical details or may be written in a way that is easy for people without technical expertise to understand.

It is also important that information is included about both the likelihood of different types of attack and the possible impact of each vulnerability on the organisation. This may include a scoring system, such as the Common Vulnerability Scoring System (CVSS), which identifies which risks are critical, high, medium, low, etc. and explains what this means for the organisation. This section will also include any deviations from security best practice which may pose a greater threat in future.

Discussion or analysis of remediation measures

After the discussion of the vulnerabilities that were found, the report will also include recommendations for remediation. These sections may be organised in terms of the difficulty of remediation. For example, starting with issues that only require simple patches or updates and can be actioned immediately and moving on to vulnerabilities that require more complicated remediation measures, such as reconfigurations or code rewrites.

Strategic recommendations

In addition to remediation guidance, the testing report may also include strategic recommendations. This discusses ways the organisation can prevent vulnerabilities in the long run. This could include an appraisal of existing security controls, feedback about operational procedures, as well as guidance on which future security investments should be prioritised.